Roteiro de apresentação

Designações do Júri · falas para o documento técnico de segurança (12 slides)

Dica: leia com calma, cerca de 1 minuto por slide (apresentação total de 10 a 12 minutos). Os termos técnicos aparecem sempre acompanhados de uma explicação simples.

CAPA · Designações do Júri

Olá a todos. Hoje vou apresentar o sistema Designações do Júri, que criamos para organizar a designação de defensores para as sessões do Tribunal do Júri. Vou mostrar como ele funciona por dentro e, principalmente, como protegemos os dados. Vou usar alguns termos técnicos, mas sempre explicando de forma simples, para que todo mundo acompanhe.

SLIDE 2 · Arquitetura

O sistema tem três partes, como uma loja: a vitrine, a entrega e o depósito. A vitrine é o site que abrimos no navegador. A entrega é a Netlify, a empresa que hospeda o site e o entrega rápido para qualquer computador. O depósito é a Supabase, onde ficam guardados os dados, num banco de dados chamado PostgreSQL. O site confere a cada 10 segundos se alguém mudou alguma coisa. Assim, todos da equipe veem a mesma informação, quase em tempo real. Ele também conversa com o Google, para calcular as distâncias entre as rodoviárias, e com o DataJud, o sistema público do CNJ, para mostrar as movimentações dos processos.

SLIDE 3 · Autenticação: como a pessoa entra

Para entrar, cada pessoa usa login e senha. A senha nunca fica guardada como foi digitada. Ela é transformada num código embaralhado, com uma técnica chamada bcrypt, que não dá para desfazer. Nem quem administra o banco consegue ver a senha. Quando a pessoa entra, recebe uma espécie de crachá digital temporário, que chamamos de sessão. Esse crachá vale por 30 dias e é cancelado quando a pessoa clica em Sair. Não existe a opção de criar conta nem de recuperar senha, justamente para diminuir as portas de entrada. E se alguém errar a senha 10 vezes em 15 minutos, o login é bloqueado por um tempo. Isso impede que um robô fique tentando adivinhar a senha.

SLIDE 4 · Autorização: quem pode ver o quê

Entrar é uma coisa. Poder ver os dados é outra. Aqui usamos um recurso chamado RLS, segurança por linha. Funciona como um porteiro dentro do próprio banco de dados: antes de entregar qualquer informação, ele confere se aquele crachá é válido. Sem crachá válido, o banco responde como se estivesse vazio. As tabelas mais sensíveis, como as de senhas e de sessões, têm uma regra de negar tudo para qualquer acesso de fora. E as funções que precisam de permissão especial ficam numa sala fechada, o schema privado, que não tem porta para a internet. O painel de segurança da própria Supabase hoje não mostra nenhum alerta.

SLIDE 5 · Proteção no navegador

Também protegemos o lado de quem usa o site. Um tipo comum de ataque é o XSS: alguém tenta esconder um código malicioso dentro de um dado, como um nome ou uma data, para que ele rode no computador de outra pessoa. Para impedir isso, o site limpa tudo o que vem do banco antes de mostrar na tela, e só aceita datas e códigos no formato correto. Além disso, configuramos regras no servidor que proíbem o site de rodar scripts de fora e de ser aberto dentro de outro site, o que evita golpes de clique falso. As ferramentas de gerar PDF ficam dentro do próprio site, sem depender de servidores de terceiros.

SLIDE 6 · Modelo de ameaças

Antes de testar, pensamos em quem poderia atacar. Primeiro, alguém de fora, que só tem o endereço do site e o que dá para ver no código. Segundo, um usuário com login que quisesse prejudicar colegas. Terceiro, um robô tentando adivinhar senhas. E por último, alguém tentando derrubar o sistema com excesso de acessos. Para cada um desses perfis, pensamos no que ele poderia tentar e colocamos uma proteção.

SLIDE 7 · Padrão internacional OWASP

A OWASP é uma organização internacional que publica a lista dos dez riscos mais comuns em aplicações web. Usamos essa lista como checklist. Controle de acesso: resolvido com o porteiro do banco. Criptografia: senhas embaralhadas e conexão sempre segura. Injeção de código: os dados nunca viram comando. Configuração: cabeçalhos de segurança ativados. Autenticação: limite de tentativas e sessões que expiram. Ou seja, cobrimos os principais pontos que essa lista recomenda.

SLIDE 8 · Como fizemos os testes de invasão

Depois de construir, atacamos o próprio sistema, como faria um invasor. Fizemos em três camadas. Na primeira, atacamos o banco de dados, fingindo ser um visitante sem permissão. Na segunda, mandamos pedidos pela internet, de fora, usando só o que qualquer pessoa conseguiria copiar do site. Na terceira, tentamos esconder códigos maliciosos nos dados e abrimos todas as telas para ver se algum código rodava. O critério para passar no teste foi simples: nenhum dado lido ou alterado sem login, nenhum código malicioso executado, e todos os dados intactos depois dos testes.

SLIDE 9 · Resultados dos ataques pela internet

Aqui estão os ataques feitos de fora, pela internet. Tentamos ler os júris sem login: o sistema devolveu uma lista vazia. Tentamos ler as senhas e as sessões: acesso negado. Inventamos um crachá falso: não funcionou. Tentamos gravar um júri falso e apagar todos os dados: bloqueado, e conferimos depois que nada foi apagado. Tentamos entrar na área privada, adivinhar senha, injetar comandos no login e usar o serviço do DataJud sem login. Todos bloqueados. Os doze ataques passaram no teste.

SLIDE 10 · Resultados no banco e na tela

Dentro do banco de dados, repetimos ataques como ler senhas, criar um usuário falso, trocar a senha de outra pessoa e até criar tabelas novas. Tudo bloqueado. Na tela, encontramos uma falha: um dado montado de forma maliciosa conseguia rodar um código em um ponto do painel. Corrigimos, testamos de novo em todas as telas e o resultado passou a ser zero. É para isso que servem os testes: achar o problema antes que alguém de fora ache.

SLIDE 11 · O que encontramos e corrigimos

Ao longo dos testes, encontramos cinco pontos e corrigimos todos. Primeiro, o login tinha uma espera que um atacante poderia usar para travar o sistema: removemos. Segundo, não havia limite de tentativas de senha: criamos o limite. Terceiro, algumas funções com permissão especial estavam numa área pública: movemos para a área privada. Quarto, as sessões não expiravam: agora valem 30 dias. Quinto, a falha de código na tela que comentei: corrigida.

SLIDE 12 · Próximos passos

Nenhum sistema é cem por cento seguro, então mostramos também o que ainda pode melhorar. O ponto principal é a senha: hoje é compartilhada e simples, e o ideal é cada pessoa ter a sua, forte, e no futuro uma verificação em duas etapas. Também recomendamos restringir as chaves do Google ao endereço do site, registrar quem alterou cada informação e garantir que o banco não pause por falta de uso. Com esses passos, o sistema fica ainda mais robusto. Obrigado, e fico à disposição para perguntas.